macro

Seven Seas A-28

Security Audit

Feb 11, 2025
Version 1.0.0

Presented by 0xMacro

Table of Contents

Introduction

This document includes the results of the security audit for Seven Seas's smart contract code as found in the section titled 'Source Code'. The security audit performed by the Macro security team over multiple days starting January 28th.

The purpose of this audit is to review the source code of certain Seven Seas Solidity contracts, and provide feedback on the design, architecture, and quality of the source code with an emphasis on validating the correctness and security of the software in its entirety.

Disclaimer: While Macro's review is comprehensive and has surfaced some changes that should be made to the source code, this audit should not solely be relied upon for security, as no single audit is guaranteed to catch all possible bugs.

Overall Assessment

The following is an aggregation of issues found by the Macro Audit team:

Severity	Count	Acknowledged	Won't Do	Addressed
Low	2	-	-	2

Seven Seas was quick to respond to these issues.

Specification

Our understanding of the specification was based on the following sources:

- Discussions with the Seven Seas team.
- Available documentation in the repository.

Source Code

The following source code was reviewed during the audit:

- **UniswapV2 Decoder (from PR 73)**

  Commit Hash: `ef6d0192c0c6ab0d4fb5d5f800320c6c1779948b`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/UniswapV2DecoderAndSanitizer.sol	`5777e164874149e3f60c465e4ebc58e17d6b6574962384351e7a0fba41282a57`

- **Royco Decoder (from PR 74)**

  Commit hash: `1ac1f8f3a6fb88abac800a0099f42603a050b541`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/RoycoDecoderAndSanitizer.sol	`e7b0113daa7bc0bca96c0ab3a05867b7e7dff9c4bb8a783c12c768a3a42c3842`

- **Royco Decoder update (from PR 91)**

  Commit hash: `f1437908bc3fbdbef9948d450192871725428b41`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/RoycoDecoderAndSanitizer.sol	`153d4b88e272b643b385e5dbf8daf0fbccc245f996e1d963c3190743c22c4250`

- **Dolomite Decoder (from PR 81)**

  Commit Hash: `6e7ca7a01bf69b3c132ad5e7ef2c04ae95f3395a`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/DolomiteDecoderAndSanitizer.sol	`42ef4d50d03ea03d37149014286bdb19f36eb59c9b769c02e7ee04e2d87e9207`

- **Kodiak Island Decoder (from PR 84)**

  Commit Hash: `3b97d95e53a086c670c485e424564390ad8d8704`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/KodiakIslandDecoderAndSanitizer.sol	`9d5a96127042b821dc88a22ac7e547bdaa3c6a6e4fd36f82249434941602ce8f`

- **Honey Decoder (from PR 85)**

  Commit Hash: `f6753b257749a5dec6643ed6896e4ae8f1262075`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/HoneyDecoderAndSanitizer.sol	`0dc14906930c9e3d7efabfa82310ee907a016a95c312fdb9267e86beb3bbaf0a`

- **Infrared Decoder (from PR 87)**

  Commit Hash: `5135a52a15f08007c4643619deb6d30e8c80fb76`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/InfraredDecoderAndSanitizer.sol	`0128c9d418be32c282e702610bfcab78ae09439c6cee5d8558c138f6afcb2843`

- **BeraETH Decoder (from PR 88)**

  Commit Hash: `fafa7f5bd19d2430f8c99cdaab71fca09ec36e13`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/BeraETHDecoderAndSanitizer.sol	`6e48416b6477de6858e266d3416ce9e7c3dddaedf742a0f30c9814ad664ce2c4`

- **Goldilocks Decoder (from PR 97)**

  Commit Hash: `33828c8c732a9f7b39a3d5c98800390fa72fa339`

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/GoldiVaultDecoderAndSanitizer.sol	`6193bc722f2ca3580eba90d03fff211995a5e1a2992a5cfcccc8296bdcfd65d2`

Note: This document contains an audit solely of the Solidity contracts listed above. Specifically, the audit pertains only to the contracts themselves, and does not pertain to any other programs or scripts, including deployment scripts.

Issue Descriptions and Recommendations

Click on an issue to jump to it, or scroll down to see them all.

Security Level Reference

We quantify issues in three parts:

1. The high/medium/low/spec-breaking **impact** of the issue:

   - How bad things can get (for a vulnerability)
   - The significance of an improvement (for a code quality issue)
   - The amount of gas saved (for a gas optimization)

2. The high/medium/low **likelihood** of the issue:

   - How likely is the issue to occur (for a vulnerability)

3. The overall critical/high/medium/low **severity** of the issue.

This third part – the severity level – is a summary of how much consideration the client should give to fixing the issue. We assign severity according to the table of guidelines below:

Severity	Description
(C-x) Critical	We recommend the client **must** fix the issue, no matter what, because not fixing would mean **significant funds/assets WILL be lost.**
(H-x) High	We recommend the client **must** address the issue, no matter what, because not fixing would be very bad, *or* some funds/assets will be lost, *or* the code's behavior is against the provided spec.
(M-x) Medium	We recommend the client to **seriously consider** fixing the issue, as the implications of not fixing the issue are severe enough to impact the project significantly, albiet not in an existential manner.
(L-x) Low	The risk is small, unlikely, or may not relevant to the project in a meaningful way. Whether or not the project wants to develop a fix is up to the goals and needs of the project.
(Q-x) Code Quality	The issue identified does not pose any obvious risk, but fixing could improve overall code quality, on-chain composability, developer ergonomics, or even certain aspects of protocol design.
(I-x) Informational	Warnings and things to keep in mind when operating the protocol. No immediate action required.
(G-x) Gas Optimizations	The presented optimization suggestion would save an amount of gas significant enough, in our opinion, to be worth the development cost of implementing it.

Issue Details

~~L-1~~ Unsanitized dolomite token addresses

TOPIC	STATUS	IMPACT	LIKELIHOOD
Sanitization	Fixed	Low	Low

In `DolomiteDecoderAndSanitizer.sol` both `closeBorrowPosition()` and `closeBorrowPositionWithDifferentAccounts()` do not sanitize the `_collateralMarketIds` of the position being closed. Although the marketIds and their associated tokens are likely already whitelisted, verifying the vault is intended to interact with these particular markets for additional safety is advised.

~~L-2~~ Missing Royco decoder function

TOPIC	STATUS	IMPACT	LIKELIHOOD
Protocol Design	Fixed	Low	High

In `RoycoDecoderAndSanitizer.sol` the function to allow withdrawals on the destination chain once able via `DepositExecutor.sol:withdrawMerkleDeposit()` is missing.

Remediations to Consider

Add the withdrawMerkleDeposit() function to `RoycoDecoderAndSanitizer.sol`.

Disclaimer

Macro makes no warranties, either express, implied, statutory, or otherwise, with respect to the services or deliverables provided in this report, and Macro specifically disclaims all implied warranties of merchantability, fitness for a particular purpose, noninfringement and those arising from a course of dealing, usage or trade with respect thereto, and all such warranties are hereby excluded to the fullest extent permitted by law.

Macro will not be liable for any lost profits, business, contracts, revenue, goodwill, production, anticipated savings, loss of data, or costs of procurement of substitute goods or services or for any claim or demand by any other party. In no event will Macro be liable for consequential, incidental, special, indirect, or exemplary damages arising out of this agreement or any work statement, however caused and (to the fullest extent permitted by law) under any theory of liability (including negligence), even if Macro has been advised of the possibility of such damages.

The scope of this report and review is limited to a review of only the code presented by the Seven Seas team and only the source code Macro notes as being within the scope of Macro's review within this report. This report does not include an audit of the deployment scripts used to deploy the Solidity contracts in the repository corresponding to this audit. Specifically, for the avoidance of doubt, this report does not constitute investment advice, is not intended to be relied upon as investment advice, is not an endorsement of this project or team, and it is not a guarantee as to the absolute security of the project. In this report you may through hypertext or other computer links, gain access to websites operated by persons other than Macro. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such websites' owners. You agree that Macro is not responsible for the content or operation of such websites, and that Macro shall have no liability to your or any other person or entity for the use of third party websites. Macro assumes no responsibility for the use of third party software and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any outcome generated by such software.